

● 22 Abr 2022

01

11.539 ETH

Akutars NFT

”11.539 ETH presos para sempre por uma linha”

STATE VARIABLE BUG · CRITICAL

~US\$34M travados permanentemente — sem hack externo, apenas um bug

0 que aconteceu

02

Akutars era uma coleção NFT de 15.000 peças do artista **Micah Johnson**, com leilão holandês que arrecadou **11.539 ETH**.

Após o leilão, o contrato deveria **reembolsar** quem pagou acima do preço final. A lógica de refund usava um loop com uma variável de estado.

O bug: **refundProgress** era atualizado **antes** de um **require** que dependia do valor anterior. O invariante quebrava, e o **require** sempre falhava.

Ninguém conseguiu ser reembolsado. E como a função de saque do owner também dependia do refund estar completo, **todo o ETH ficou preso para sempre** — sem nenhum atacante envolvido.

● Contrato Vulnerável

03

INHA VULNERÁVEL

● ● ● SOLIDITY / VULNERABLE

6

```
...ed"); // Nunca chega aqui payable(refundAddresses[i]) .transfer(refundAmounts[i]); } }
```

Lição

Loops de estado devem preservar os invariantes dos require seguintes. Teste edge cases com fuzz testing.

Como o bug funcionou

ESTADO INICIAL

refundProgress = 0, totalBids = 3592



ITERAÇÃO i = 3591

refundProgress = 3591 + 1 = 3592



CHECK

require(3592 < 3592) → FALSE → REVERT!



CONSEQUÊNCIA 1

Último refund nunca processa



CONSEQUÊNCIA 2

withdraw() requer refund completo



RESULTADO

11.539 ETH trancados PERMANENTEMENTE

Contrato imutável · Sem escape hatch

● Verifique na Blockchain

05

Transação com revertetherscan.io/tx/0x583a5a...3547Contrato Akutarsetherscan.io/address/0xF42c3...961d